

Arquitectura de Seguridad - Corto Plazo (0-3 meses)

Caso Bankitor - TO-BE

1. Contexto del Problema

Bankitor es una entidad financiera peruana regulada por la **SBS** con más de 10 años en el mercado. Cuenta con un SOC tercerizado y políticas de seguridad definidas. Sin embargo, sufrió dos incidentes críticos:

Incidente	Descripción	Brecha detectada
Caída de Internet	Cambio de configuración en router de borde dejó sin conexión a Internet	No había registro de qué comandos se ejecutaron ni quién los ejecutó
Modificación en BD de Créditos	Saldos de deuda de clientes fueron cambiados a cero	No se pudo identificar qué DBA o aplicación ejecutó el cambio

Además, Bankitor tiene banca por Internet expuesta que aún no ha sufrido brechas, pero que representa un riesgo latente que debe ser atendido de forma proactiva.

2. Objetivo del Corto Plazo

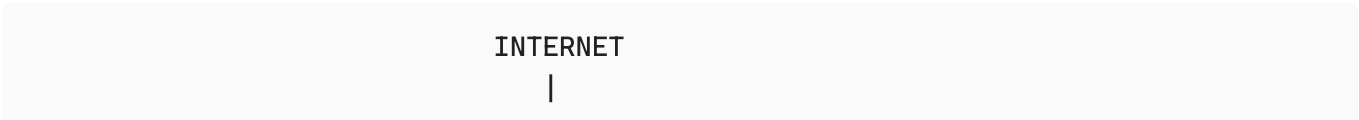
Cerrar de forma inmediata las brechas que ya causaron incidentes reales y reforzar los controles perimetrales antes de que ocurra una brecha en banca por Internet.

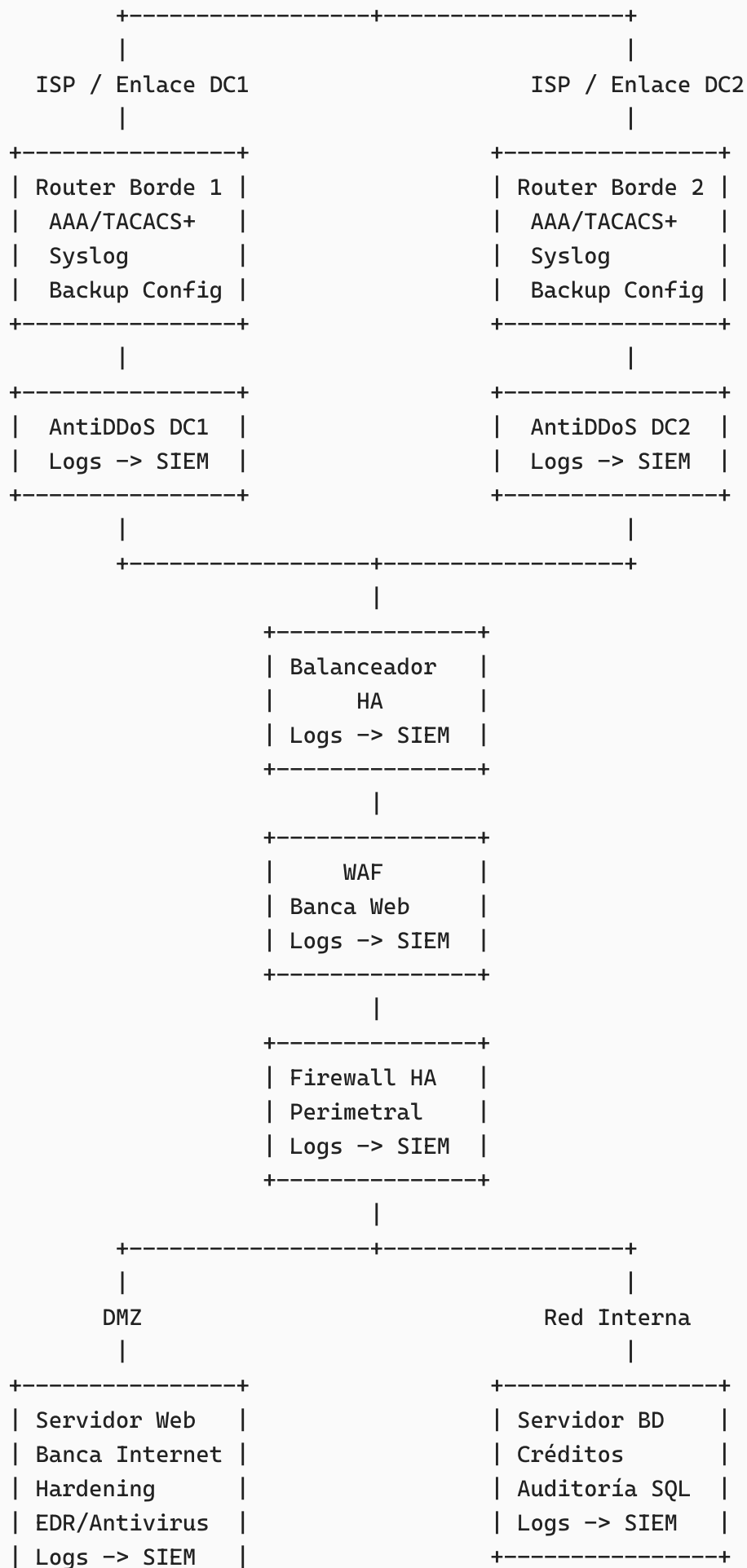
Principio guía: Defensa en profundidad — múltiples capas de control independientes.

Duración: 3 meses

Enfoque: Trazabilidad, disponibilidad, protección web y auditoría de base de datos.

3. Diagrama General de la Arquitectura TO-BE Corto Plazo







- Bankitor tiene dos datacenters. Si un enlace falla, el otro mantiene el servicio.

- El incidente ocurrió porque el router de borde se afectó y no había camino alternativo activo.

Validaciones necesarias:

- Proveedores ISP distintos (diversidad de proveedor).
- Rutas físicas diferentes (diversidad de ruta).
- Monitoreo de disponibilidad y alertas ante saturación o caída.
- Procedimiento de conmutación documentado.

4.3 Router de Borde

El incidente de Bankitor ocurrió aquí. Un cambio de configuración causó la caída de Internet y no hubo registro de qué comandos se ejecutaron.

Mejoras propuestas (sin cambiar arquitectura física):

Control	Función
AAA / TACACS+	Registra quién ingresó, qué permisos tenía y qué comandos ejecutó
Syslog	Envía eventos al SIEM para análisis y evidencia forense
Backup de configuración	Permite comparar antes/después de un cambio y hacer rollback rápido
Registro de comandos	Evidencia de cada acción ejecutada en el equipo

Ejemplo de lo que TACACS+ registraría:

```
Usuario:    jperez
Equipo:     Router Borde DC1
Comando:    no shutdown interface g0/1
Hora:       22:15:03
Origen IP:  10.10.50.20
Resultado:  Aceptado
```

¿Por qué TACACS+ y no RADIUS?

TACACS+ separa autenticación, autorización y auditoría. Permite registrar comandos ejecutados comando por comando, lo que RADIUS no hace de la misma forma.

4.4 AntiDDoS

Qué protege: Disponibilidad del servicio ante ataques volumétricos.

Posición: Después del router, antes de la capa de aplicación. Filtra tráfico masivo antes de que consuma recursos internos.

Por qué en ambos datacenters: Ambos DC tienen salida a Internet. Proteger solo uno deja el otro expuesto.

Eventos que debe enviar al SIEM:

- Ataques volumétricos detectados.
 - IPs bloqueadas.
 - Activación de mitigación.
 - Saturación del enlace.
 - Cambios de política.
-

4.5 Balanceador en Alta Disponibilidad (HA)

Qué hace: Distribuye conexiones entre múltiples servidores web.

Por qué HA: Un balanceador único es punto único de falla. Si cae, aunque los servidores funcionen, los clientes no pueden acceder.

Configuración recomendada: Activo / Pasivo (failover automático).

Logs al SIEM:

- IP origen de clientes.
 - Servidor destino asignado.
 - Estado de salud de cada nodo.
 - Conexiones rechazadas o errores.
 - Caídas de servidores detectadas.
-

4.6 WAF - Web Application Firewall

Qué es: Firewall especializado en proteger aplicaciones web. Complementa al firewall tradicional.

Por qué es necesario para Bankitor:

- La banca por Internet maneja operaciones financieras sensibles.
- Un firewall tradicional permite HTTPS (puerto 443) pero no detecta ataques dentro del tráfico cifrado.
- El WAF inspecciona el contenido de las solicitudes web.

Ataques que detecta y bloquea:

Ataque	Descripción
SQL Injection	Inyección de código SQL en formularios o URLs
XSS	Cross-Site Scripting
Fuerza bruta	Intentos masivos de login
Bots	Tráfico automatizado no autorizado
Manipulación de parámetros	Modificación de valores en URLs o formularios
Escaneo de rutas	Descubrimiento de recursos ocultos
Ataques a APIs	Explotación de endpoints de la banca móvil/web

Ejemplo de ataque que el firewall dejaría pasar pero el WAF bloquearía:

```
GET /consulta?id=1 OR 1=1--  
Host: bankitor.com
```

El firewall ve: tráfico HTTPS válido.

El WAF ve: intento de SQL Injection. → BLOQUEAR.

Logs al SIEM:

- Ataques bloqueados y reglas activadas.
- IPs sospechosas con geolocalización.
- URLs atacadas.
- User-Agent sospechoso.
- Intentos de fuerza bruta.

4.7 Firewall Perimetral en HA

Qué hace: Controla y segmenta el tráfico entre zonas de red (Internet, DMZ, Red Interna).

Reglas base recomendadas:

Origen	Destino	Puerto	Acción
Internet	Servidor Web DMZ	443	Permitir
Internet	Red Interna	Cualquier	Bloquear
Internet	BD Créditos	Cualquier	Bloquear
DMZ	BD Créditos	Puerto App	Permitir (controlado)
DMZ	Red Interna libre	Cualquier	Bloquear
Admin (Bastion)	Equipos críticos	SSH/RDP	Permitir

Por qué HA:

Un firewall único que falla puede cortar el acceso a la banca por Internet, aislar la DMZ o afectar la red interna. Con HA activo/pasivo hay failover automático.

Logs al SIEM:

- Conexiones permitidas y bloqueadas.
 - Cambios de reglas.
 - Login administrativo.
 - Tráfico anómalo.
-

4.8 DMZ (Zona Desmilitarizada)

Qué es: Zona intermedia entre Internet y la red interna. Aloja servicios accesibles desde Internet.

Qué debe estar en la DMZ:

- Servidor web / portal de banca por Internet.
- Reverse proxy (si aplica).

Qué NO debe estar en la DMZ:

- Base de datos de créditos.
- Directorio Activo.
- Servidores de archivos.
- Consolas administrativas.
- Core bancario.

Por qué la separación importa: Si un atacante compromete el servidor web, el daño debe quedar contenido en la DMZ. No debe poder acceder libremente a la red interna.

4.9 Servidor Web / Banca por Internet

Posición: En la DMZ. Accesible desde Internet, pero protegido por WAF y Firewall.

Mejoras propuestas:

Control	Acción
Hardening	Desactivar servicios innecesarios, cerrar puertos, eliminar usuarios por defecto
TLS seguro	Solo TLS 1.2/1.3, sin cifrados débiles
EDR / Antivirus	Detección de comportamientos maliciosos en el servidor
Logs al SIEM	Eventos del sistema operativo y de la aplicación
Parches actualizados	Proceso de parchado regular
Monitoreo de integridad	Alerta si archivos del servidor son modificados

4.10 Servidor de Base de Datos de Créditos

El segundo incidente de Bankitor ocurrió aquí. Saldos de deuda fueron cambiados a cero y no se pudo identificar quién lo hizo.

Mejora crítica: Auditoría SQL activa

Qué debe registrar:

Campo	Detalle
Usuario	Cuenta que ejecutó la sentencia
IP origen	Desde dónde se conectó
Tabla afectada	Nombre de la tabla
Sentencia SQL	El comando exacto ejecutado
Filas afectadas	Cuántos registros fueron modificados
Fecha y hora	Timestamp exacto

Campo	Detalle
Resultado	Éxito o error

Ejemplo de alerta crítica que el SIEM debería recibir:

```
ALERTA CRÍTICA - Modificación masiva en tabla de créditos
Tabla:          credits
Campo:          saldo_deuda
Nuevo valor:    0
Filas afect.:  150
Usuario DB:     app_creditos
IP origen:      10.10.40.25
Hora:          02:15:33 AM
```

Esta alerta no existía en el incidente anterior. Con la mejora, el SOC sería notificado en tiempo real.

4.11 Proxy / Control de Navegación

Qué hace: Intermediario para la salida a Internet de usuarios internos.

Beneficios:

- Bloquear sitios maliciosos o de riesgo.
- Registrar qué sitios visitan los usuarios.
- Detectar comunicación con dominios sospechosos (C2 de malware).
- Aplicar políticas de navegación por categoría.

Logs al SIEM:

- URL visitadas.
 - Categorías bloqueadas.
 - Dominios sospechosos consultados.
 - Equipos que intentan conectarse a dominios de malware.
-

4.12 Antivirus / EDR

Tecnología	Descripción
Antivirus	Detecta malware conocido por firmas
EDR	Detecta comportamientos sospechosos. Más avanzado.

Despliegue en corto plazo:

- Servidor web (DMZ).
- Servidor de base de datos.
- Equipos de usuarios internos.
- Equipos de administradores.

En corto plazo: Centralizar los logs del antivirus existente hacia el SIEM como primer paso.

Evolución: Migrar a EDR administrado en el mediano plazo.

4.13 SIEM y SOC

SIEM (Security Information and Event Management): Centraliza, correlaciona y analiza eventos de seguridad de todos los componentes.

El SIEM no está en la ruta del tráfico. Recibe logs de todos los equipos:

Router	→ logs → SIEM
AntiDDoS	→ logs → SIEM
Balanceador	→ logs → SIEM
WAF	→ logs → SIEM
Firewall	→ logs → SIEM
Servidor Web	→ logs → SIEM
BD Créditos	→ logs → SIEM
Proxy	→ logs → SIEM
EDR/Antivirus	→ logs → SIEM

Casos de uso del SOC en corto plazo:

Caso de Uso	Descripción	Prioridad
Cambio de configuración en router	Alerta cuando se modifica configuración	Crítica
Login admin fuera de horario	Acceso fuera de ventana autorizada	Alta
Modificación masiva en BD créditos	UPDATE con muchas filas afectadas	Crítica

Caso de Uso	Descripción	Prioridad
Ataques bloqueados por WAF	Patrones de ataque web	Alta
Caída de enlace	Pérdida de conectividad	Crítica
Acceso DBA sospechoso	DBA conectado desde IP no habitual	Alta
Tráfico DMZ → Red Interna inusual	Posible movimiento lateral	Alta
Múltiples intentos de login fallidos	Fuerza bruta	Media

4.14 MFA - Autenticación Multifactor

Qué es: Segundo factor de autenticación además de la contraseña.

Dónde aplicar en corto plazo (prioridad):

1. Acceso VPN / remoto de administradores.
2. Cuentas con acceso a router y firewall.
3. Cuentas DBA con acceso a base de datos de créditos.
4. Cuentas de acceso al SIEM.

Tipos de segundo factor:

- Aplicación móvil (TOTP: Google Authenticator, Microsoft Authenticator).
- Token físico.
- Código push de aprobación.

4.15 VPN Segura / Bastion Host

VPN segura: Canal cifrado para acceso remoto de administradores.

Bastion Host (Jump Server): Servidor intermedio desde donde se administran sistemas críticos.

Flujo correcto:

Administrador → VPN + MFA → Bastion → Router / Firewall / BD / Servidor

Flujo incorrecto (a eliminar):

Beneficios del Bastion:

- Centraliza todos los accesos administrativos.
- Registra sesiones completas.
- Restringe origen de conexiones.
- Facilita auditoría de accesos privilegiados.
- Reduce exposición de equipos críticos.

5. Relación Componente - Riesgo - Incidente

Componente	Riesgo que reduce	Relación con incidente Bankitor
Router + AAA/TACACS+	Cambios no atribuibles	Incidente 1: No se sabía qué comandos se ejecutaron
Syslog centralizado	Falta de evidencia forense	Permite reconstruir qué ocurrió
Backup de configuración	Error operativo sin rollback	Permite revertir en minutos
AntiDDoS	Caída por saturación de enlace	Protege disponibilidad del acceso a Internet
Balanceador HA	Punto único de falla web	Continuidad del servicio de banca
WAF	Ataques a banca por Internet	Protege antes de que ocurra la brecha
Firewall HA	Acceso entre zonas no autorizado	Contiene movimiento lateral
DMZ separada	Exposición directa de red interna	Aísla servicios públicos
Servidor Web endurecido	Compromiso del portal web	Reduce superficie de ataque
BD con Auditoría SQL	Cambios en datos no identificados	Incidente 2: No se supo quién puso saldos a cero
Proxy	Navegación riesgosa y exfiltración	Controla salida a Internet
EDR/Antivirus	Malware en endpoints y servidores	Detecta amenazas internas

Componente	Riesgo que reduce	Relación con incidente Bankitor
SIEM	Falta de correlación de eventos	Centraliza evidencia de ambos incidentes
SOC con casos de uso	Falta de respuesta oportuna	Alerta proactiva ante anomalías
MFA	Robo de credenciales	Protege accesos privilegiados
Bastion Host	Acceso administrativo sin control	Centraliza y audita administración

6. Supuestos Asumidos

1. Bankitor tiene dos datacenters físicos activos (DC1 y DC2).
2. Los 500 Mbps por enlace son la capacidad actual; se mantienen en corto plazo.
3. El SOC tercerizado puede recibir y operar con los logs del SIEM.
4. El servidor web de banca por Internet está en la DMZ (se confirma en corto plazo).
5. La base de datos de créditos está en la red interna (no en DMZ).
6. El antivirus ya existe; se centraliza su log en corto plazo.
7. Los administradores de TI tienen acceso remoto; se controla con VPN + MFA + Bastion.

7. Actividades del Corto Plazo (3 meses)

Mes 1

- ☐ Configurar AAA/TACACS+ en routers de borde DC1 y DC2.
- ☐ Activar Syslog en routers hacia colector centralizado.
- ☐ Implementar backup automatizado de configuración de routers y firewalls.
- ☐ Activar auditoría SQL en base de datos de créditos.
- ☐ Configurar envío de logs de BD al SIEM.

Mes 2

- ☐ Desplegar WAF para banca por Internet.
- ☐ Configurar reglas base del WAF (OWASP Top 10).
- ☐ Implementar MFA para accesos VPN y cuentas administrativas.
- ☐ Configurar Bastion Host con registro de sesiones.

- ☐ Centralizar logs de antivirus en el SIEM.

Mes 3

- ☐ Activar casos de uso críticos en el SIEM (modificación BD, cambio router, login fuera de horario).
 - ☐ Realizar hardening de servidor web (TLS, puertos, servicios, permisos).
 - ☐ Validar configuración HA del balanceador y del firewall.
 - ☐ Validar que AntiDDoS envíe logs al SIEM.
 - ☐ Revisión y prueba de casos de uso con el SOC tercerizado.
-

8. Lo que NO se hace en corto plazo (y por qué)

Tecnología	Por qué se difiere
Zero Trust	Requiere rediseño profundo de arquitectura y procesos
PAM completo	Requiere selección, implementación e integración con directorio
SOAR	Requiere madurez del SIEM y procesos del SOC definidos
Microsegmentación total	Requiere mapeo completo de tráfico y pruebas extensas
IDS/IPS completo	Se prioriza en mediano plazo después de tener visibilidad SIEM
DLP	Requiere clasificación de datos y políticas previas

9. Cumplimiento Regulatorio

Estas mejoras responden a requerimientos de la SBS (Superintendencia de Banca, Seguros y AFP):

Mejora	Marco regulatorio relacionado
Auditoría SQL en BD	Circular SBS G-140-2009 - Gestión de Seguridad de Información
Logs y trazabilidad	Circular SBS G-140-2009 - Gestión de eventos de seguridad
MFA para accesos privilegiados	Buenas prácticas SBS - Control de accesos
WAF y protección web	Protección de canales digitales y banca por Internet

Mejora	Marco regulatorio relacionado
SIEM / SOC	Monitoreo continuo de seguridad

Documento: Arquitectura de Seguridad Bankitor - Corto Plazo (3 meses)

Clasificación: Uso interno - Trabajo académico ESAN